

# Security+ 2.2 · Common Threat Vectors

Mestre CyberSec — Guia Completo CompTIA Security+ (SY0-701) · Aula 2.2 — Common Threat Vectors  
(17:14) · [Vídeo no YouTube ↗](#)

**Resumo da Aula:** Vetores = como o ataque chega: email/SMS/voz, imagem, arquivo, chamada, credencial default nunca trocada, software infectado, USB baiting, malvertising (anúncio malicioso), credential stuffing (reuso de senha vazada), insider, rede remota, IoT/nuvem física.

## 💡 Highlights que a prova cobra

- Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA
- Malvertising: anúncio malicioso em site legítimo
- Credential stuffing = USAR senha vazada em outros sites (vs brute force)

## 🎯 Dicas de prova & Cenários Típicos

- 'reuses leaked credentials across multiple sites' = credential stuffing
- 'malicious advertisement on a legitimate website' = malvertising

**Cenário clássico de exame:** Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing.

 **Além do Vídeo: O que a CompTIA cobra na prova (Conceitos, Siglas e**

## Armadilhas da Seção 2.2)

**Por que este aprofundamento é cobrado no exame?** O vídeo do Professor Messer (Common Threat Vectors) resume os conceitos de forma ágil. Contudo, a banca examinadora oficial da CompTIA (SY0-701) exige raciocínio prático de engenharia de segurança, diferenciação entre protocolos concorrentes e aplicação em cenários corporativos reais. Entenda os conceitos complementares fundamentais:

- **Atores de Ameaça (Threat Actors):** **Nation-state / APT (Advanced Persistent Threat):** altamente financiado, sofisticado, motivado por espionagem geopolítica a longo prazo. **Cybercriminal:** motivado por lucro financeiro direto (ransomware, extorsão). **Hacktivist:** motivado por causas políticas ou ideológicas. **Insider Threat:** funcionário ou terceiro com acesso legítimo que abusa de privilégios por dolo ou negligência.
- **Engenharia Social e Variantes de Phishing:** **Phishing:** campanha em massa por e-mail. **Spear Phishing:** ataque direcionado a indivíduo ou empresa específica usando dados de OSINT. **Whaling:** direcionado a executivos do C-level (CEO, CFO). **Vishing:** phishing por voz/telefone. **Smishing:** phishing por SMS. **BEC (Business Email Compromise):** impersonação de diretoria para desvio de faturas ou transferências bancárias.
- **Tipos de Malware e Vetores de Ataque:**
  - *Ransomware:* cifra dados corporativos e exige resgate em criptomoeda.
  - *Trojan:* software aparentemente inofensivo que instala backdoors ocultos.
  - *Rootkit:* modifica o kernel do sistema operacional e se oculta de ferramentas antivírus comuns.
  - *Worm:* malware autorreplicável que se propaga sozinho pela rede sem intervenção humana.
- **Vulnerabilidades de Aplicação (OWASP Top 10):**
  - *SQL Injection (SQLi):* manipulação de queries de banco de dados por falta de sanitização/parametrização (prepared statements).
  - *XSS (Cross-Site Scripting):* injeção de scripts maliciosos (JavaScript) no navegador da vítima.
  - *CSRF (Cross-Site Request Forgery):* induz a vítima logada a executar ações indesejadas em uma aplicação web confiável.

### ⚠ **Armadilhas e Pegadinhas Clássicas da Banca:**

- Phishing não é mitigado apenas por filtros de e-mail; o controle humano fundamental é a simulação periódica de phishing e conscientização.
- Rootkits operam no nível de anel de privilégio (Ring 0 / Kernel), exigindo verificação de Secure Boot (TPM) para prevenção confiável.

## ✓ Perguntas de treino comentadas (10 questões)

---

Gabarito com resolução passo a passo e análise dos distratores no fim. Tente responder antes de olhar.

**1. No 'acesso inicial' de um ransomware moderno, qual é a falha MAIS explorada?**

- A)** Firewall mal configurado
- B)** Phishing + VPN sem MFA / credencial vazada
- C)** Cabo de rede exposto
- D)** Falta de antivírus

**2. Atacante testa senhas VAZADAS de um site em VÁRIOS outros sites (reúso de senha):**

- A)** Credential stuffing
- B)** Força bruta pura
- C)** Rainbow table
- D)** Vishing

**3. Comprometer um fornecedor de software pra atingir todos os clientes dele (ex: SolarWinds):**

- A)** Ataque de cadeia de suprimentos
- B)** Watering hole
- C)** Insider
- D)** Zero-day

**4. Cenário corporativo (Common Threat Vectors):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**5. Cenário corporativo (Common Threat Vectors):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Malvertising: anúncio malicioso em site legítimo'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Malvertising: anúncio malicioso em site legítimo...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**6. Cenário corporativo (Common Threat Vectors):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Credential stuffing = USAR senha vazada em outros sites (vs brute force)'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: Credential stuffing = USAR senha vazada em outros sites (vs brute force)...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**7. Cenário corporativo (Common Threat Vectors):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'reuses leaked credentials across multiple sites' = credential stuffing'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Permitir acesso compartilhado entre administradores com credenciais genéricas
- D)** Implementar a solução correspondente: 'reuses leaked credentials across multiple sites' = credential stuffing...

**8. Cenário corporativo (Common Threat Vectors):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'malicious advertisement on a legitimate website' = malvertising'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Implementar a solução correspondente: 'malicious advertisement on a legitimate website' = malvertising...
- B)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**9. Cenário corporativo (Common Threat Vectors):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing.'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Implementar a solução correspondente: Cenário típico: 'atacante usou senhas vazadas de um data breach em outras c...
- C)** Substituir controles técnicos preventivos por termos de adesão informais
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

**10. Cenário corporativo (Common Threat Vectors):** Durante uma revisão de segurança e auditoria de conformidade com o exame CompTIA Security+ (SY0-701, Seção 2.2), um analista avalia o seguinte requisito técnico: 'Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA'. Qual é a melhor recomendação ou classificação de controle aplicável?

- A)** Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema
- B)** Substituir controles técnicos preventivos por termos de adesão informais
- C)** Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA...
- D)** Permitir acesso compartilhado entre administradores com credenciais genéricas

## GABARITO COMENTADO COM ANÁLISE DE DISTRATORES

### 1) B — Phishing + VPN sem MFA / credencial vazada.

✓ **Por que está certa:** A entrada quase sempre é humana/credencial: phishing, VPN sem segundo fator, ou login vazado por infostealer. Por isso MFA em TUDO é a defesa nº1.

#### ✗ **Por que as outras estão erradas:**

- *Firewall mal configurado:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Cabo de rede exposto:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Falta de antivírus:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 2) A — Credential stuffing.

✓ **Por que está certa:** Credential stuffing = reusar credenciais vazadas em outros serviços. Força bruta testa combinações; dictionary usa lista de palavras comuns.

#### ✗ **Por que as outras estão erradas:**

- *Força bruta pura:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Rainbow table:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Vishing:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 3) A — Ataque de cadeia de suprimentos.

✓ **Por que está certa:** Supply chain attack compromete um elo confiável (fornecedor) pra alcançar muitos alvos de uma vez.

#### ✗ **Por que as outras estão erradas:**

- *Watering hole:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Insider:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.
- *Zero-day:* Não atende ao requisito técnico apresentado no cenário, contrariando as boas práticas e controles exigidos pelo exame CompTIA Security+.

### 4) B — Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA....

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA.

#### ✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.

- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**5) C — Implementar a solução correspondente: Malvertising: anúncio malicioso em site legítimo....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Malvertising: anúncio malicioso em site legítimo.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**6) A — Implementar a solução correspondente: Credential stuffing = USAR senha vazada em outros sites (vs brute force)....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Credential stuffing = USAR senha vazada em outros sites (vs brute force).

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**7) D — Implementar a solução correspondente: 'reuses leaked credentials across multiple sites' = credential stuffing....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): 'reuses leaked credentials across multiple sites' = credential stuffing.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema*: Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais*: Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas*: Destroi a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**8) A — Implementar a solução correspondente: 'malicious advertisement on a legitimate website' = malvertising....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): 'malicious advertisement on a legitimate website' = malvertising.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**9) B — Implementar a solução correspondente: Cenário típico: 'atacante usou senhas vazadas de um data breach em outras c....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Cenário típico: 'atacante usou senhas vazadas de um data breach em outras contas dos mesmos usuários' = credential stuffing..

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.

**10) C — Implementar a solução correspondente: Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA....**

✓ **Por que está certa:** Conforme os objetivos oficiais do exame CompTIA Security+ (SY0-701) para a aula 2.2 (Common Threat Vectors): Vetores: mensagem, arquivo, credencial, USB, rede, IoT, cloud, FÍSICA.

✗ **Por que as outras estão erradas:**

- *Desativar temporariamente os logs de auditoria para acelerar o throughput do sistema:* Viola frontalmente o pilar de Accounting e a rastreabilidade forense. Sem logs, a equipe fica cega para detectar incidentes e quebra normas de conformidade (PCI DSS, ISO 27001).
- *Substituir controles técnicos preventivos por termos de adesão informais:* Termos informais são controles administrativos, dependem exclusivamente da conduta do usuário e não bloqueiam ataques automatizados, injeções ou malwares em tempo de execução.
- *Permitir acesso compartilhado entre administradores com credenciais genéricas:* Destrói a

responsabilização individual (Accountability) e o Não-repúdio. Torna impossível comprovar quem realizou alterações críticas ou comandos maliciosos.